



Weekly IT Security Brief (Official-source-first) | 2026-05-10 06:03

Formatted for readability · Auto-generated



Weekly Summary

- Priority snapshot: 3 KEV-listed vulnerabilities are actively exploited in the wild (top 8 shown in this brief).
- Urgent patch focus: CVE-2026-42208(2026-05-11), CVE-2026-6973(2026-05-10), CVE-2026-0300(2026-05-09). Prioritize internet-facing and privileged systems first.
- Threat trend #1: Active attack: Dirty Frag Linux vulnerability expands post-compromise risk. Dirty Frag is a newly disclosed Linux local privilege escalation vulnerability affecting kernel networking and memory-fragment handling components including esp4, esp...
- Threat trend #2: When prompts become shells: RCE vulnerabilities in AI agent frameworks. Content types Research Products and services Microsoft Defender Topics Actionable threat insights AI and agents In this article A representative case study: Semantic Kern...
- Recommended action this week: patch KEV/high-risk exposed services within 24 hours and tighten monitoring for anomalous login, command execution, and credential access patterns.



Report A: CVE Deep Dive (CISA KEV + NVD)

CVE-2026-42208

CVE Title	CVE-2026-42208 litellm/litellm Unknown Type
CVE Description	LiteLLM is a proxy server (AI Gateway) to call LLM APIs in OpenAI (or native) format. From version 1.81.16 to before version 1.83.7, a database query used during proxy API key checks mixed the caller-supplied key value into the query text instead of passing it as a separate parameter. An unauthenticated attacker could send a specially crafted Authorization header to any LLM API route (for example POST /chat/completi...
Root Cause	Use vendor advisories and patch notes for authoritative technical details.
Exploitation Prerequisite	Affected version is reachable through an exploitable path and remains unpatched.
Exploit Path	Attacker leverages public PoC or observed exploit chain for intrusion.
Affected Products	litellm/litellm
Risk Score	9.8 (CRITICAL)
Exploited in the wild	Listed in CISA KEV
KEV remediation due date	2026-05-11
Mitigation	Apply vendor patches immediately, reduce internet exposure, harden WAF/ACL controls, and enable anomaly detection. Since active exploitation is observed, patch high-risk assets within 24 hours.
Source	https://www.cisa.gov/known-exploited-vulnerabilities-catalog
Source	https://nvd.nist.gov/vuln/detail/CVE-2026-42208

CVE-2026-6973

CVE Title	CVE-2026-6973 ivanti/endpoint_manager_mobile Remote Code Execution
CVE Description	An Improper Input Validation in Ivanti EPMM before versions 12.6.1.1, 12.7.0.1, and 12.8.0.1 allows a remotely authenticated user with administrative access to achieve remote code execution.
Root Cause	Unsafe deserialization or input-handling flaws enable arbitrary code execution.
Exploitation Prerequisite	Relevant endpoint is exposed and unpatched.
Exploit Path	Malicious request/payload -> vulnerability trigger -> remote command execution.
Affected Products	ivanti/endpoint_manager_mobile
Risk Score	7.2 (HIGH)
Exploited in the wild	Listed in CISA KEV
KEV remediation due date	2026-05-10
Mitigation	Apply vendor patches immediately, reduce internet exposure, harden WAF/ACL controls, and enable anomaly detection. Since active exploitation is observed, patch high-risk assets within 24 hours.
Source	https://www.cisa.gov/known-exploited-vulnerabilities-catalog
Source	https://nvd.nist.gov/vuln/detail/CVE-2026-6973

CVE-2026-0300

CVE Title	CVE-2026-0300 paloaltonetworks/pan-os Buffer Overflow
CVE Description	A buffer overflow vulnerability in the User-ID™ Authentication Portal (aka Captive Portal) service of Palo Alto Networks PAN-OS software allows an unauthenticated attacker to execute arbitrary code with root privileges on the PA-Series and VM-Series firewalls by sending specially crafted packets.
Root Cause	Authentication workflow has logical flaws allowing bypass.
Exploitation Prerequisite	Target service is network-reachable and accepts attacker-crafted unauthorized requests.
Exploit Path	Unauthorized request -> auth bypass -> sensitive data access / privileged operations.
Affected Products	paloaltonetworks/pan-os, paloaltonetworks/pa-1410, paloaltonetworks/pa-1420, paloaltonetworks/pa-3410, paloaltonetworks/pa-3420
Risk Score	9.8 (CRITICAL)
Exploited in the wild	Listed in CISA KEV
KEV remediation due date	2026-05-09
Mitigation	Apply vendor patches immediately, reduce internet exposure, harden WAF/ACL controls, and enable anomaly detection. Since active exploitation is observed, patch high-risk assets within 24 hours.
Source	https://www.cisa.gov/known-exploited-vulnerabilities-catalog
Source	https://nvd.nist.gov/vuln/detail/CVE-2026-0300



Report A2: Newly Published CVEs (NVD, last 7 days)

CVE-2026-7669

CVE Title	CVE-2026-7669 待核實 Unknown Type
CVE Description	A vulnerability was detected in sgl-project SGLang up to 0.5.9. Impacted is the function get_tokenizer of the file python/sglang/srt/utils/hf_transformers_utils.py of the component HuggingFace Transformer Handler. The manipulation of the argument trust_remote_code with the input False as part of Boolean results in code injection. The attack can be executed remotely. A high complexity level is associated with this at...
Affected Products	待核實
Risk Score	5.6 (MEDIUM)
Source	https://nvd.nist.gov/vuln/detail/CVE-2026-7669

CVE-2026-6481

CVE Title	CVE-2026-6481 待核實 Unknown Type
CVE Description	Rejected reason: This CVE ID has been rejected or withdrawn by its CVE Numbering Authority.
Affected Products	待核實
Risk Score	待核實 (待核實)
Source	https://nvd.nist.gov/vuln/detail/CVE-2026-6481

CVE-2026-7670

CVE Title	CVE-2026-7670 待核實 SQL Injection
CVE Description	A flaw has been found in Jinher OA 1.0. The affected element is an unknown function of the file /C6/JHSoft.Web.PlanSummarize/UserSel.aspx. This manipulation of the argument DeptIDList causes sql injection. The attack is possible to be carried out remotely. The exploit has been published and may be used. The vendor was contacted early about this disclosure but did not respond in any way.
Affected Products	待核實
Risk Score	7.3 (HIGH)
Source	https://nvd.nist.gov/vuln/detail/CVE-2026-7670

CVE-2026-7671

CVE Title	CVE-2026-7671 待核實 Unknown Type
CVE Description	A vulnerability has been found in CodeWise Tornet Scooter Mobile App 4.75 on iOS/Android. The impacted element is an unknown function of the file /TwoFactor. Such manipulation leads to improper restriction of excessive authentication attempts. The attack may be performed from remote. Attacks of this nature are highly complex. The exploitability is regarded as difficult. The exploit has been disclosed to the public a...
Affected Products	待核實
Risk Score	3.7 (LOW)
Source	https://nvd.nist.gov/vuln/detail/CVE-2026-7671

CVE-2026-7672

CVE Title	CVE-2026-7672 待核實 SQL Injection
CVE Description	A security vulnerability has been detected in youlaitech youlai-boot up to 2.21.1. This affects the function getUserList of the file src/main/java/com/youlai/boot/system/controller/UserController.java of the component Users Endpoint. Such manipulation of the argument order leads to sql injection. The attack may be launched remotely. The exploit has been disclosed publicly and may be used. The vendor was contacted ea...
Affected Products	待核實
Risk Score	6.3 (MEDIUM)
Source	https://nvd.nist.gov/vuln/detail/CVE-2026-7672

CVE-2026-40561

CVE Title	CVE-2026-40561 kazuho/starlet Unknown Type
CVE Description	Starlet versions through 0.31 for Perl allows HTTP Request Smuggling via Improper Header Precedence.
Affected Products	kazuho/starlet
Risk Score	5.3 (MEDIUM)
Source	https://nvd.nist.gov/vuln/detail/CVE-2026-40561



Report B: Threat Intelligence News (last 7 days)

Headline: Active attack: Dirty Frag Linux vulnerability expands post-compromise risk

Source	Microsoft Security Blog
Published	Fri, 08 May 2026 17:12:46 +0000
Key Takeaway	Dirty Frag is a newly disclosed Linux local privilege escalation vulnerability affecting kernel networking and memory-fragment handling components including esp4, esp6, and rxrpc. The vulnerability enables reliable escalation from an unprivileged user to root and may be leveraged after initial compr Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral mov...
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	ot/待核實
Technique	Exploit Chain
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://www.microsoft.com/en-us/security/blog/2026/05/08/active-attack-dirty-frag-linux-vulnerability-expands-post-compromise-risk/

Headline: When prompts become shells: RCE vulnerabilities in AI agent frameworks

Source	Microsoft Security Blog
Published	Thu, 07 May 2026 20:22:39 +0000
Key Takeaway	Content types Research Products and services Microsoft Defender Topics Actionable threat insights AI and agents In this article A representative case study: Semantic Kernel CVE-2026-26030: In-Memory Vector Store CVE-2026-25592: Arbitrary file write through SessionsPythonPlugin The vulnerability Atta Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral mov...
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	ot/待核實
Technique	待核實
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://www.microsoft.com/en-us/security/blog/2026/05/07/prompts-become-shells-rce-vulnerabilities-ai-agent-frameworks/

Headline: CISA Unveils New Initiative to Fortify America’s Critical Infrastructure

Source	CISA News
Published	Tue, 05 May 26 12:00:00 +0000
Key Takeaway	CISA Unveils New Initiative to Fortify America’s Critical Infrastructure
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	critical infrastructure/待核實
Technique	待核實
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://www.cisa.gov/news-events/news/cisa-unveils-new-initiative-fortify-americas-critical-infrastructure

Headline: CISA, US and International Partners Release Guide to Secure Adoption of Agentic AI

Source	CISA News
Published	Fri, 01 May 26 12:00:00 +0000
Key Takeaway	CISA, US and International Partners Release Guide to Secure Adoption of Agentic AI
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	unknown-target
Technique	待核實
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://www.cisa.gov/news-events/news/cisa-us-and-international-partners-release-guide-secure-adoption-agentic-ai

Headline: Snow Flurries: How UNC6692 Employed Social Engineering to Deploy a Custom Malware Suite

Source	Mandiant Blog
Published	Thu, 23 Apr 2026 14:00:00 +0000
Key Takeaway	Following this, the attacker sent a phishing message via Microsoft Teams, posing as helpdesk personnel offering assistance with the email volume. Finally, EDR telemetry logged the threat actor performing screen captures on the Domain Controllers, specifically targeting in-focus instances of Microsoft Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral mov...
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	defense/待核實
Technique	T1003.001,T1003.002,T1003.003
MITRE ATT&CK	T1003.001, T1003.002, T1003.003, T1005, T1007, T1012, T1016, T1018, T1020, T1021.001, T1021.002, T1027, T1027.010, T1027.015, T1033, T1036.005, T1046, T1053, T1053.005, T1055, T1057, T1059, T1059.001, T1059.003, T1059.006, T1059.007, T1059.010, T1068, T1070.004, T1071.001, T1074, T1082, T1083, T1087.001, T1090, T1105, T1110.001, T1110.003, T1112, T1113, T1134, T1134.001, T1140, T1176.001, T1202, T1204.001, T1204.002, T1489, T1518, T1543, T1543.003, T1547.001, T1547.009, T1552.001, T1559, T1560, T1560.001, T1562.001, T1564.001, T1566.002, T1567, T1567.002, T1569.002, T1572, T1608.002, T1608.005, T1622
Related CVEs	None
Link	https://cloud.google.com/blog/topics/threat-intelligence/unc6692-social-engineering-custom-malware/

Headline: Defending Your Enterprise When AI Models Can Find Vulnerabilities Faster Than Ever

Source	Mandiant Blog
Published	Thu, 16 Apr 2026 14:00:00 +0000
Key Takeaway	Introduction Advances in AI model-powered exploitation have demonstrated that general-purpose AI models can excel at vulnerability discovery, even without being purpose-built for the task. Eventually, capabilities such as these will be integrated directly into the development cycle, and code will be Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral mov...
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	defense/global
Technique	Ransomware
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://cloud.google.com/blog/topics/threat-intelligence/defending-enterprise-ai-vulnerabilities/

Headline: Unplug your way to better code

Source	Cisco Talos Blog
Published	Thu, 07 May 2026 18:00:40 GMT
Key Takeaway	Unplug your way to better code Blog Intelligence Center Intelligence Center BACK Intelligence Search Email & Spam Trends Vulnerability Research Vulnerability Research BACK Vulnerability Reports Microsoft Advisories Incident Response Incident Response BACK Reactive Services Proactive Services Emergen Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral...
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	unknown-target
Technique	待核實
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://blog.talosintelligence.com/unplug-your-way-to-better-code/

Headline: Insights into the clustering and reuse of phone numbers in scam emails

Source	Cisco Talos Blog
Published	Wed, 06 May 2026 10:00:12 GMT
Key Takeaway	Insights into the clustering and reuse of phone numbers in scam emails Blog Intelligence Center Intelligence Center BACK Intelligence Search Email & Spam Trends Vulnerability Research Vulnerability Research BACK Vulnerability Reports Microsoft Advisories Incident Response Incident Response BACK Reac Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral...
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	unknown-target
Technique	待核實
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://blog.talosintelligence.com/insights-into-the-clustering-and-reuse-of-phone-numbers-in-scam-emails/

Headline: cPanel, WHM Release Fixes for Three New Vulnerabilities — Patch Now

Source The Hacker News

Published Sat, 09 May 2026 12:46:00 +0530

Key Takeaway cPanel has released updates to address three vulnerabilities in cPanel and Web Host Manager (WHM) that could be exploited to achieve privilege escalation, code execution, and denial-of-service. The list of vulnerabilities is as follows - CVE-2026-29201 (CVSS score: 4.3) - An insufficient input valid Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral mov...

Summary Engine extractive-rules

Threat Actors Not explicitly stated

Target unknown-target

Technique Exploit Chain

MITRE ATT&CK Unverified

Related CVEs CVE-2026-29201

Link <https://thehackernews.com/2026/05/cpanel-whm-patch-3-new-vulnerabilities.html>

Headline: TCLBANKER Banking Trojan Targets Financial Platforms via WhatsApp and Outlook Worms

Source The Hacker News

Published Fri, 08 May 2026 23:42:00 +0530

Key Takeaway Threat hunters have flagged a previously undocumented Brazilian banking trojan dubbed TCLBANKER that's capable of targeting 59 banking, fintech, and cryptocurrency platforms. The activity is being tracked by Elastic Security Labs under the moniker REF3076. Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral movement.

Summary Engine extractive-rules

Threat Actors Not explicitly stated

Target financial/待核實

Technique Malware Deployment

MITRE ATT&CK Unverified

Related CVEs None

Link <https://thehackernews.com/2026/05/tclbanker-banking-trojan-targets.html>

Headline: In Other News: Train Hacker Arrested, PamDOORa Linux Backdoor, New CISA Director Frontrunner

Source	SecurityWeek
Published	Fri, 08 May 2026 14:30:00 +0000
Key Takeaway	In Other News: Train Hacker Arrested, PamDOORa Linux Backdoor, New CISA Director Frontrunner - SecurityWeek SECURITYWEEK NETWORK: Cybersecurity News Webcasts Virtual Events ICS: ICS Cybersecurity Conference Malware & Threats Cyberwarfare Cybercrime Data Breaches Fraud & Identity Theft Nation-State R Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lat...
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	ot/asia
Technique	Malware Deployment
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://www.securityweek.com/in-other-news-train-hacker-arrested-pamdoora-linux-backdoor-new-cisa-director-frontrunner/

Headline: Polish Security Agency Reports ICS Breaches at Five Water Treatment Plants

Source	SecurityWeek
Published	Fri, 08 May 2026 11:46:06 +0000
Key Takeaway	The post Polish Security Agency Reports ICS Breaches at Five Water Treatment Plants appeared first on SecurityWeek . Polish Security Agency Reports ICS Breaches at Five Water Treatment Plants - SecurityWeek SECURITYWEEK NETWORK: Cybersecurity News Webcasts Virtual Events ICS: ICS Cybersecurity Confe Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral mov...
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	ics/待核實
Technique	待核實
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://www.securityweek.com/polish-security-agency-reports-ics-breaches-at-five-water-treatment-plants/

Sources (official/authoritative first)

<https://www.cisa.gov/known-exploited-vulnerabilities-catalog>

<https://nvd.nist.gov/>

<https://www.cve.org/>

[**https://attack.mitre.org/**](https://attack.mitre.org/)

[**https://www.microsoft.com/en-us/security/blog/**](https://www.microsoft.com/en-us/security/blog/)

[**https://www.cisa.gov/news-events/cybersecurity-advisories**](https://www.cisa.gov/news-events/cybersecurity-advisories)

[**https://www.mandiant.com/resources**](https://www.mandiant.com/resources)

[**https://blog.talosintelligence.com/**](https://blog.talosintelligence.com/)